ドメイン保護のためのアーキテクチャ原則

2026-10-03 時点。実装やレビューで守る境界を記す。構成の根拠はDocker/API1計画 (../plans/mrst-docker-environment-plan.html)、msnc実装計画 (../plans/msnc-crawler-implementation-plan.html)および現在のCompose設定。未実装の業務機能まで実装済みと扱わない。

実行環境と責務

- APIと運用管理Webは services/mrst の同一 Laravel 13 アプリ。API1ではFrankenPHP/PHP 8.5のWeb、キューワーカー、単一Schedulerを独立したプロセスとして動かす。公開サイトは別の静的配信経路。
- msncのLaravelキューが取得元の登録、スケジュール、安全なHTTP取得、再試行、PostgreSQLへの保存、AIとの連携を所有する。Python/BeautifulSoupは取得済みHTMLの解析のみ担当し、常駐HTTPサービスにしない。
- Python子プロセスは外部HTTP、DB、AIの通信を行わない。 Laravelから標準入力のJSON契約で媒体コード・抽出版・取得済みHTMLを受け、標準出力にJSON一件を返す。stdoutは診断に使わず、stderrにも原文・資格情報を出さない。入力・出力サイズと実行時間を親側で制限し、子プロセスにDBパスワードやAIキーを渡さない。
- クロール対象は許可済みのURL・ホストだけ。DNS解決と各リダイレクト後の接続先IPを再検証し、内部・予約アドレス、資格情報付きURL、許可外ポートを拒否する。記事内の指示やAI出力を運用コマンドとして実行しない。

データと公開境界

- 一次資料、rawニュース、AI入力・生ログ、審査中候補、管理者情報、メールアドレス、IP由来識別子、トークン、秘密鍵は非公開領域に置く。公開S3バケット morashiter-site-prod への個人情報・非公開データ・APIキーの混入を禁止する。
- msgnだけが公開用資格情報を持つ。msnc/msic/msjdに公開バケットへの書込権限を渡さない。公開物は承認済み版から許可リスト方式で生成し、ビルド成果物をアップロード前に検査する。
- wwwの静的閲覧は動的PostgreSQLから完全に切り離す。DBの審査状態が変わっても、承認と配信完了を経ない限り公開ページは変えない。公開APIが将来必要でも、静的ビルドへ購読者・希望者の生データを埋め込まない。
- 原資料・AI記録・監査ログは削除・保持方針が決まるまで公開成果物に含めない。異なる単位、対象範囲、確実性の情報を変換・合算するロジックを無承認で追加しない。

DB接続と整合性

- 開発・本番の通常のWeb/worker/Scheduler通信はPgBouncerのtransaction pooling経由とする。長時間の外部HTTP取得中にDBトランザクションを保持しない。セッション固定に依存するSQL・接続状態は設計レビューなしに導入しない。
- マイグレーション、DDL、テストはPgBouncerを通さずPostgreSQLへ直接接続する。Mac開発環境では通常 pgbouncer:6432 → mrst、テスト db:5432 → mrst_test。テストのパスワードは既存Compose環境変数を使い、RefreshDatabase が開発DB mrst を初期化しないよう接続先を強制・検証する。
- 本番の mrst は他プロジェクトのDBと分離する。本番DB名、ロール、接続権限、マイグレーション用の直接経路はAPI1/DB管理者と確定してから設定する。Macの mrst_test を本番へ持ち込まない。
- 承認と配信要求の記録にはDBトランザクションと一意な要求キーを用い、外部S3/CDN操作は冪等なジョブとして再試行する。配信成功前に公開版ポインターを変えない。失敗時の旧版復元方法を実装・検証する。

管理境界と変更ルール

- /admin は専用管理者認証、権限、CSRF、固定IP許可リストを適用する。IP制限は信頼済みプロキシの利用者IPだけを参照し、空の許可リストでは拒否する。現在のログイン基盤が審査承認機能まで完成したとは扱わない。

- 単一AIの推論だけによる公開は禁止する。 2つ以上の独立したAI（異なるモデルまたは独立プロンプト）が同じ資料版を検証し、抽出内容・企業・漏えい確実性・数値と単位・一次資料の根拠位置に完全合意し、重大な不確実性がない場合は approval_method=ai_consensus で自動承認を許す。一次資料なし、不一致、訂正・撤回・重大な削除、設定された重大インシデントの要レビュー条件では review_required とする。人手で承認する場合は approval_method=manual と管理者・理由を記録する。
- ai_consensus の承認証跡には、参加した各AIのモデル名・版、実行時のプロンプト、判定理由、検証結果、合意タイムスタンプ、対象資料の版とハッシュを含める。秘密情報や原文を公開バケットへ出さず、評価履歴を非公開で後から監査できるように保持する。評価失敗・ログ欠落・ポリシー設定不足では自動承認しない。
- 設計変更時は本 docs/ddd/、テーブル案HTML/JSON、msnc計画、マイグレーション、公開生成契約の差分を照合する。特に用語、列の意味、状態遷移、公開許可フィールドを独断で変更しない。未決事項はTODOとして根拠と判断者を示し、仮値を「確定仕様」として定着させない。

実装前に検証する契約

1. Python stdin/stdout JSONのスキーマ、媒体コード許可リスト、抽出版、サイズ・時間上限をfixture試験で固定する。
2. PostgreSQL実DBで重複排除、版番号、資料参照、配信要求の整合性を試験する。
3. 複数AIの完全一致での自動承認と、不一致・一次資料欠落・訂正・重大閾値超過・評価ログ欠落での人手レビューを試験する。承認前、公開失敗、訂正、撤回の各状態で、静的成果物に許可外情報が入らず旧公開版が維持されることも検証する。
4. 本番経路で管理画面のIP制限、信頼プロキシ、認証と公開APIからの迂回不能を検証する。